

Phụ Lục: Báo Cáo Kiểm Toán AI (AI Audit Report)

Sinh viên thực hiện: Lâm Hữu Khánh

Mã số sinh viên: 23127205

Môn học: Kiểm thử phần mềm (Software Testing) — HW06: Kiểm thử API & Ứng dụng AI

Thời gian thực hiện: 30/08/2026 – 31/08/2026

1. Khai Báo Sử Dụng AI (Mandatory AI Declaration)

"I use AI tools for the following tasks:"

- Phân tích đặc tả yêu cầu SUT (`eshop-sut/api_specification.md` và `eshop-sut/README.md`) để sinh test cases API có cấu trúc cho 3 API được chọn:
 - Pool A:** FR-02 — Đăng nhập & Khóa tài khoản (`POST /api/login`)
 - Pool B:** FR-07 — Giỏ hàng (`GET /api/cart` , `POST /api/cart`)
 - Pool C:** FR-15 — Quản lý sản phẩm CRUD (`POST/GET/PUT/DELETE /api/products`)
- Chuyển đổi tài liệu đặc tả API sang chuẩn OpenAPI 3.0 (`docs/openapi.yaml`).
- Thiết kế các kịch bản kiểm thử JSON Schema Validation (`ajv`) và Chai Assertions cho Postman Tests.
- Xây dựng sơ đồ kiến trúc và mã nguồn triển khai cho Agent Skill (G9.5 Create: AI API Test Generator).

2. Nhật Ký Toàn Bộ Các Phiên Tương Tác AI (Detailed AI Audit Logs)

[+] Phiên 1: Sinh Test Cases cho FR-02 — Đăng Nhập & Khóa Tài Khoản (`POST /api/login`)

- Tên công cụ AI: Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- Ngày và giờ: 2026-08-30 20:15:30 +07:00
- Prompt của bạn:

```
```text
Bạn là một Senior API QA Automation Engineer.
Dựa trên tài liệu đặc tả hệ thống EShop (SRS & api_specification.md):

Endpoint: POST /api/login
Body: { "email": "string", "password": "string" }

Yêu cầu nghiệp vụ FR-02:

1. Đăng nhập thành công trả về 200 OK kèm JWT token và user object (gồm id, role, email, name).
2. Mỗi lần đăng nhập sai thông tin, bộ đếm login_attempts tăng đúng 1 đơn vị.
3. Nếu đăng nhập sai 3 lần liên tiếp, tài khoản bị tạm khóa 30 giây (trả về 403 Forbidden).
4. Sau khi hết 30s hoặc đăng nhập đúng, bộ đếm được reset về 0.
5. Bảo mật: Mật khẩu không lưu plaintext (SEC-01), chống SQL Injection (SEC-05), chống Brute-force.
```

Hãy thiết kế 38 Test Cases có cấu trúc bảng rõ ràng, phân bổ theo 4 kỹ thuật kiểm thử:

- Phân hoạch miền (Equivalence Partitioning & Boundary Value Analysis)
- Chuyển trạng thái (State Transition Testing cho chu trình khóa tài khoản)
- Bảo mật (Security Testing: SQLi, Brute-force, Tampered Token)
- Schema Validation (JSON Schema response 200, 400, 401, 403)

Mỗi test case phải có: TestID, Coverage Type, Description, Request Body, Expected Status Code, Expected Response.

...

• Đầu ra của AI:

```
```markdown
### A. Phân hoạch miền & Giá trị biên (Domain Partitioning - 14 TCs) | TestID | Coverage
Type | Mô tả | Request Body | Expected Status | Expected Response Shape | |---|---|---|---|:---:|---|
| TC_FR02_DOM_01 | Domain Valid | Đăng nhập tài khoản user chuẩn |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"...","user":
{...}} | | TC_FR02_DOM_02 | Domain Valid | Đăng nhập tài khoản admin chuẩn |
{"email":"admin@eshop.com","password":"Admin123!"} | 200 | {"message":"Login
successful","token":"...","user":{"role":"admin"}} | | TC_FR02_DOM_03 | Domain Invalid | Email sai định dạng
(thiếu @) | {"email":"testeshop.com","password":"Test1234!"} | 400 | {"error": string} | | TC_FR02_DOM_04 |
Domain Invalid | Email sai định dạng (thiếu domain) | {"email":"test@","password":"Test1234!"} | 400 |
{"error": string} | | TC_FR02_DOM_05 | Domain Invalid | Email để trống chuỗi rỗng |
{"email":"","password":"Test1234!"} | 400 | {"error": string} | | TC_FR02_DOM_06 | Domain Invalid | Thiếu hân
trường email trong JSON | {"password":"Test1234!"} | 400 | {"error": string} | | TC_FR02_DOM_07 | Domain
Invalid | Password để trống chuỗi rỗng | {"email":"test@eshop.com","password":""} | 400 | {"error": string} |
| TC_FR02_DOM_08 | Domain Invalid | Thiếu hân trường password | {"email":"test@eshop.com"} | 400 |
{"error": string} | | TC_FR02_DOM_09 | Domain Invalid | Cả email và password đều rỗng |
{"email":"","password":""} | 400 | {"error": string} | | TC_FR02_DOM_10 | Domain Invalid | Password sai giá
trị | {"email":"test@eshop.com","password":"WrongPass999!"} | 401 | {"error":"Invalid email or password"} | |
TC_FR02_DOM_11 | Domain Invalid | Email không tồn tại trong hệ thống |
{"email":"nonexistent@eshop.com","password":"Test1234!"} | 401 | {"error":"Invalid email or password"} | |
TC_FR02_DOM_12 | Boundary | Email cực dài (255 ký tự hợp lệ) |
{"email":"a...a@eshop.com","password":"Test1234!"} | 401 | {"error":"Invalid email or password"} | |
TC_FR02_DOM_13 | Boundary | Password 7 ký tự (dưới chuẩn 8 ký tự) |
{"email":"test@eshop.com","password":"Pass12!"} | 401 | {"error":"Invalid email or password"} | |
TC_FR02_DOM_14 | Domain Invalid | Kiểu dữ liệu email là số | {"email":12345,"password":"Test1234!"} | 400
| {"error": string}```
```

B. Chuyển trạng thái (State Transition - 9 TCs)

```
| TestID | Coverage Type | Mô tả | Request Body | Expected Status | Expected Response Shape |
|---|---|---|---|:---:|---|
| TC_FR02_ST_01 | State Transition | Đăng nhập sai lần 1 (Counter = 1) |
{"email":"lockout_target@eshop.com","password":"wrong"} | 401 | {"error":"Invalid email or password"} |
| TC_FR02_ST_02 | State Transition | Đăng nhập sai lần 2 (Counter = 2) |
{"email":"lockout_target@eshop.com","password":"wrong"} | 401 | {"error":"Invalid email or password"} |
| TC_FR02_ST_03 | State Transition | Đăng nhập sai lần 3 -> Chuyển sang LOCKED (30s) |
{"email":"lockout_target@eshop.com","password":"wrong"} | 401 | {"error":"Invalid email or password"} |
| TC_FR02_ST_04 | State Transition | Đăng nhập khi tài khoản đang bị khóa (Lần 4) |
{"email":"lockout_target@eshop.com","password":"Lockout123!"} | 403 | {"error":"Tài khoản đã bị khóa. Vui
lòng thử lại sau."} |
| TC_FR02_ST_05 | State Transition | Nhập sai pass khi tài khoản đang bị khóa |
{"email":"lockout_target@eshop.com","password":"wrong"} | 403 | {"error":"Tài khoản đã bị khóa. Vui lòng
thử lại sau."} |
| TC_FR02_ST_06 | State Transition | Đăng nhập đúng sau khi hết thời gian khóa 30s |
{"email":"lockout_target@eshop.com","password":"Lockout123!"} | 200 | {"message":"Login
successful","token":"..."} |
| TC_FR02_ST_07 | State Transition | Reset Counter: Sai 1 lần rồi nhập đúng ngay |
```

```

{"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"..."} |
| TC_FR02_ST_08 | State Transition | Khóa tài khoản không ảnh hưởng đến user khác |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"..."} |
| TC_FR02_ST_09 | State Transition | Đăng nhập đúng liên tiếp không bị khóa |
{"email":"test@eshop.com","password":"Test1234!"} | 200 | {"message":"Login successful","token":"..."} |

```

C. Bảo mật (Security Testing - 9 TCs)

```

| TestID | Coverage Type | Mô tả | Request Body | Expected Status | Expected Response Shape |
|---|---|---|---|---|---|
| TC_FR02_SEC_01 | SQL Injection | SQLi bypass cơ bản trong email | {"email":"' OR 1=1 --", "password":"any"} | 401 | {"error":"Invalid email or password"} |
| TC_FR02_SEC_02 | SQL Injection | SQLi bypass dạng boolean | {"email":"admin@eshop.com' OR '1'='1", "password":"any"} | 401 | {"error":"Invalid email or password"} |
| TC_FR02_SEC_03 | SQL Injection | SQLi trong password | {"email":"admin@eshop.com", "password":"' OR 1=1 --"} | 401 | {"error":"Invalid email or password"} |
| TC_FR02_SEC_04 | XSS | XSS script payload trong email | {"email":"<script>alert(1)</script>@eshop.com", "password":"pass"} | 400 | {"error": "string"} |
| TC_FR02_SEC_05 | Brute Force | Gửi request liên tục 10 lần với dictionary passwords | Lặp lại POST /api/login | 403 | Tài khoản phải bị khóa từ lần 3 |
| TC_FR02_SEC_06 | Header Injection | Header Content-Type không hợp lệ (text/plain) | Body: plain text | 400 / 415 | Unsupported Media Type |
| TC_FR02_SEC_07 | Password Leak | Kiểm tra response 200 không chứa password hash/plaintext | {"email":"test@eshop.com","password":"Test1234!"} | 200 | Response user KHÔNG chứa trường password |
| TC_FR02_SEC_08 | Token Signing | JWT Token trả về phải có 3 phần tách biệt bởi dấu chấm | {"email":"test@eshop.com","password":"Test1234!"} | 200 | token.split('.').length === 3 |
| TC_FR02_SEC_09 | Error Message Obfuscation | Sai email hoặc sai pass đều trả về cùng 1 thông báo chung | {"email":"wrong","password":"wrong"} | 401 | error === "Invalid email or password" |

```

D. Kiểm tra Schema (Schema Validation - 6 TCs)

```

| TestID | Coverage Type | Mô tả | Request Body | Expected Status | Expected Schema |
|---|---|---|---|---|---|
| TC_FR02_SCH_01 | Schema 200 | Validate cấu trúc Response thành công | {"email":"test@eshop.com","password":"Test1234!"} | 200 | JSON Schema: {message: string, token: string, user: {id: int, role: string, ...}} |
| TC_FR02_SCH_02 | Schema 401 | Validate cấu trúc Response lỗi 401 | {"email":"test@eshop.com","password":"wrong"} | 401 | JSON Schema: {error: string} |
| TC_FR02_SCH_03 | Schema 403 | Validate cấu trúc Response khóa 403 | {"email":"locked@eshop.com","password":"pass"} | 403 | JSON Schema: {error: string} |
| TC_FR02_SCH_04 | Schema Content-Type | Header Content-Type trả về phải là application/json | {"email":"test@eshop.com","password":"Test1234!"} | 200 | Content-Type: application/json; charset=utf-8 |
| TC_FR02_SCH_05 | Schema Token Format | Token phải là chuỗi định dạng JWT hợp lệ | {"email":"test@eshop.com","password":"Test1234!"} | 200 | Regex: ^[A-Za-z0-9-_=]+\.[A-Za-z0-9-_=]+\.[A-Za-z0-9-_.+/=]*$ |
| TC_FR02_SCH_06 | Schema 400 | Validate cấu trúc Response lỗi 400 khi body rỗng | {} | 400 / 401 | JSON Schema: {error: string} |
...

```

- **Đánh giá kiểm toán của con người (Human Audit Decision):**
- **Nhãn tổng hợp:** 26 **VALID**, 5 **INVALID**, 7 **INCOMPLETE**.
- **Chi tiết kiểm toán:**

- `TC_FR02_DOM_03` ~ `DOM_06` (`INVALID`): AI giả định backend trả về `400 Bad Request` khi email sai định dạng, nhưng thực tế `server.js` truy vấn CSDL trả về `401`. Chuyển các test này sang `02_Bug_Discovery_Suite` để bắt bug thiếu validation format của SUT.
- `TC_FR02_DOM_14` (`INVALID`): Gửi email dạng số, SQLite tự ép kiểu thành string. Sửa lại assertion để test không bị gây trên SUT.
- `TC_FR02_SEC_07` (`INCOMPLETE`): AI chưa đưa ra assertion cụ thể `pm.expect(jsonData.user).to.not.have.property('password')`. Đã bổ sung code Chai assertion.
- `TC_FR02_ST_03` (`INCOMPLETE`): AI không phát hiện bug của SUT: `login_attempts` tăng +2 mỗi lần và khóa 180s thay vì 30s. Đã ghi nhận bug này vào `bug-reports/member-1.md`.
- Các Test Cases còn lại (`VALID`): Đúng đặc tả, logic rõ ràng, đầy đủ input và expected output.

[+] Phiên 2: Sinh Test Cases cho FR-07 — Giỏ Hàng (`GET /api/cart` , `POST /api/cart`)

- **Tên công cụ AI:** Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- **Ngày và giờ:** 2026-08-30 21:30:15 +07:00
- **Prompt của bạn:**

```
```text
Bạn là một Senior API QA Automation Engineer.
Dựa trên tài liệu đặc tả EShop cho FR-07 (Giỏ hàng):
```
- **Endpoints:** `GET /api/cart`, `POST /api/cart`
- **Yêu cầu Header:** Authorization: Bearer
- **Body khi thêm giỏ:** { "id": number, "name": string, "price": number, "quantity": number }
- **Nhiệm vụ:**
  1. Người dùng thêm sản phẩm vào giỏ hàng cá nhân.
  2. Thêm cùng 1 sản phẩm nhiều lần thì tăng số lượng quantity.
  3. Phải đăng nhập mới xem/thêm được giỏ hàng.
  4. Không cho phép xem/sửa giỏ hàng của người dùng khác (chống IDOR).
  5. Validation: quantity > 0, product\_id phải hợp lệ.

Hãy thiết kế 38 Test Cases bao phủ: Phân hoạch miền (12 TC), Chuyển trạng thái (10 TC), Bảo mật SEC-01~07 (9 TC), Schema Validation (7 TC).

...

- **Đầu ra của AI:**

```
```markdown
```

A. Phân hoạch miền & Biên (12 TCs)

- `quantity`: 1 (biên hợp lệ), 0 (invalid), âm (-1), số thực (1.5), số cực lớn (999999).
- `id`: ID tồn tại (1..5), ID không tồn tại (99999), ID âm (-1), ID kiểu chuỗi ("abc").
- `price`: giá khớp CSDL, giá bị can thiệp client-side.
- `name`: tên sản phẩm rỗng, tên sản phẩm hợp lệ.

B. Chuyển trạng thái (10 TCs)

- Giỏ hàng ban đầu rỗng `[]` -> Thêm sản phẩm A (SL 1) -> Thêm tiếp sản phẩm A (SL tăng thành 2) -> Thêm sản phẩm B -> Giỏ hàng có 2 items.

- Test case giả định `PUT /api/cart` sửa SL và `DELETE /api/cart/:id` xóa item.

C. Bảo mật (9 TCs)

- Request không mang Header Authorization -> 401 Unauthorized.

- Request mang JWT token giả mạo / hết hạn -> 403 Forbidden.
- IDOR: User A cố gắng truy cập giỏ hàng User B.
- SQLi trong các trường payload body.

D. Schema Validation (7 TCs)

- Schema Response 200 của `GET /api/cart` (mảng các item có id, name, price, quantity).
- Schema Response 200 của `POST /api/cart` (`{"message": "Added to cart"}`).
- Schema Response lỗi 401/403.

...

- **Đánh giá kiểm toán của con người (Human Audit Decision):**
- **Nhãn tổng hợp:** 24 `VALID` , 6 `INVALID` , 8 `INCOMPLETE` .
- **Chi tiết kiểm toán:**
 - `INVALID` (6 TCs): AI tự giả định backend có các endpoint `PUT /api/cart` và `DELETE /api/cart` theo mô tả giao diện, nhưng thực tế `server.js` chỉ có `GET` và `POST` . Đã chuyển các test này thành Bug Report kiến trúc.
 - `INCOMPLETE` (8 TCs): AI không nhận ra giỏ hàng lưu in-memory (`userCarts = {}`), dữ liệu giỏ hàng sẽ bị mất sạch khi server khởi động lại. Đã bổ sung kịch bản kiểm tra tính bền vững của dữ liệu giỏ hàng.
 - `VALID` (24 TCs): Các kịch bản phân hoạch `quantity` , kiểm tra token `401 Unauthorized` , và cấu trúc Schema `GET /api/cart` được giữ nguyên.

[+] Phiên 3: Sinh Test Cases cho FR-15 — Quản Lý Sản Phẩm CRUD (`POST/GET/PUT/DELETE /api/products`)

- **Tên công cụ AI:** Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- **Ngày và giờ:** 2026-08-30 22:45:00 +07:00
- **Prompt của bạn:**

```
```text
Bạn là một Senior API QA Automation Engineer.
Dựa trên đặc tả FR-15 (Product CRUD):
```

  - `POST /api/products` (Thêm mới: name, price, description, imageUrl, category\_id)
  - `GET /api/products/:id` (Xem chi tiết)
  - `PUT /api/products/:id` (Cập nhật)
  - `DELETE /api/products/:id` (Xóa)
  - Yêu cầu quyền: Chỉ Admin mới được Thêm/Sửa/Xóa (SEC-03).
  - Validation: Tên bắt buộc <= 255 ký tự; Price > 0; Category\_id phải tồn tại.

Hãy thiết kế 38 Test Cases phân bổ cho 4 methods, bao phủ Domain, State Transition, Security, Schema.

...

- **Đầu ra của AI:**

```
```markdown
### Phân bổ 38 Test Cases:
```

 - `POST /api/products` (12 TCs): BVA giá (>0, =0, âm), tên SP rỗng/255 ký tự, category tồn tại/không tồn tại, token Admin vs User.
 - `PUT /api/products/:id` (10 TCs): Cập nhật từng trường, cập nhật giá âm, ID không tồn tại (404), token Admin vs User.
 - `DELETE /api/products/:id` (8 TCs): Xóa sản phẩm tồn tại, xóa ID không tồn tại, xóa lần 2, token Admin vs User.

- GET /api/products/:id (8 TCs): Lấy SP ID 1, lấy SP ID không tồn tại, lấy SP ID dạng chữ, Schema JSON. ...
- **Đánh giá kiểm toán của con người (Human Audit Decision):**
- **Nhãn tổng hợp:** 27 **VALID**, 4 **INVALID**, 7 **INCOMPLETE**.
- **Chi tiết kiểm toán:**
 - **INVALID** (4 TCs): AI giả định backend kiểm tra `authenticateToken` ở `POST/PUT/DELETE /api/products`, nhưng soi `server.js` thấy SUT hoàn toàn quên gắn middleware `authenticateToken` vào các route này (Bất kỳ ai cũng thêm/xóa được sản phẩm!). Chuyển thành Bug Bảo mật Nghiêm trọng (Critical Security Bug).
 - **INCOMPLETE** (7 TCs): AI không phát hiện bug của SUT ở dòng 162 `server.js`: `if (row.id % 2 === 0) row.price = row.price.toString();` (ID chẵn bị ép kiểu price sang string!). Đã bổ sung test case schema bất lỗi sai kiểu dữ liệu này.
 - **VALID** (27 TCs): Các kịch bản kiểm tra CRUD, BVA giá và tên sản phẩm được giữ nguyên.

[+] Phiên 4: Chuyển Đổi Đặc Tả SUT sang Chuẩn OpenAPI 3.0

- **Tên công cụ AI:** Google Antigravity (Claude 3.7 Sonnet / Gemini 2.0 Flash)
- **Ngày và giờ:** 2026-08-31 09:15:00 +07:00
- **Prompt của bạn:**

text Hãy chuyển đổi toàn bộ đặc tả API Markdown từ file eshop-sut/api_specification.md thành định dạng OpenAPI 3.0 YAML (docs/openapi.yaml) đầy đủ endpoints, components schemas, parameters, securitySchemes (BearerAuth) và response status codes.
- **Đầu ra của AI:**

Tạo file `docs/openapi.yaml` chứa toàn bộ 15+ API endpoints của EShop với đầy đủ components schemas (`User`, `Product`, `CartItem`, `Order`, `Coupon`) và securitySchemes `BearerAuth`.
- **Đánh giá kiểm toán của con người (Human Audit Decision):**
- **Nhãn:** **VALID** sau khi bổ sung thêm mô tả lỗi 403 Forbidden cho các API Admin và chuẩn hóa kiểu dữ liệu `price` là integer.

3. Bảng Tổng Hợp Kết Quả Kiểm Toán Số Liệu

Phân hệ API	Tổng số TC AI sinh	Số TC Hợp lệ (VALID)	Số TC Không hợp lệ (INVALID)	Số TC Thiếu sót (INCOMPLETE)	Số TC Đã chỉnh sửa
FR-02 (Đăng nhập & Khóa TK)	38	31 (81.6%)	5 (13.2%)	2 (5.3%)	7
FR-07 (Giỏ hàng)	38	30 (78.9%)	3 (7.9%)	5 (13.2%)	8
FR-15 (Quản lý sản phẩm CRUD)	38	31 (81.6%)	5 (13.2%)	2 (5.3%)	7
TỔNG CỘNG	114	92 (80.7%)	13 (11.4%)	9 (7.9%)	22